Supplementary Material: Biometric-Bound Zero-Knowledge Voting: A Comparative Analysis of Face and Iris Identity in an End-to-End Verifiable Decentralized Architecture

Mahin R. Chowdhury*Student Member IEEE*, Arpita Das*Student Member IEEE*, K. M. Azharul Hasan*Student Member IEEE* *Department of Computer Science and Engineering,
Khulna University of Engineering & Technology,
Khulna, Dhaka, Bangladesh

Appendix A
Reproducibility Appendix

A. Data and Artifact Sources

All benchmark tables and plots in Section VI are derived from the following artifact files in the project repository:

- `fabric-samples/zkp-chain/api-server/compareBenchmarks/benchmark_results.json`
- `fabric-samples/zkp-chain/api-server/benchmark/e2e_results.json`
- `fabric-samples/zkp-chain/api-server/benchmark/homomorphic_results.json`
- `fabric-samples/zkp-chain/api-server/benchmark/e2e_scalability_results.json`

Generated manuscript assets are placed under:

- `generated_assets/tables/`
- `generated_assets/figures/`

B. Asset Generation Procedure

The benchmark tables and figures are generated by:

```
python3temp_paper_source/generate_
        manuscript_assets.py
```

The script reads the JSON artifacts and emits publication-ready LaTeX table snippets and PNG figures used directly in this paper.

C. Evaluation Scope Notes

The current benchmark release includes both deterministic circuit metrics and pipeline timings with controlled components. Where full production-network measurements are not enabled, this is explicitly disclosed in Section VI to avoid overstatement.

D. Supplementary Benchmark Figures and Tables

To preserve traceability to benchmark outputs, the following supplementary figures are included directly from the benchmark output directory as publication-quality vector PDFs.

1) ZK-SNARK Core Performance:
2) Circuit Complexity and Throughput:
3) Artifact Sizes and Nullifier Security:
4) Merkle Tree Scalability:
5) E2E Pipeline and Scalability:
6) Homomorphic Tallying and Comparative Benchmarks:

Appendix B
Circuit Architecture Details

This section provides the full details of the circuit signals and constraint complexity breakdown referenced in the main manuscript.

A. Circuit Signals

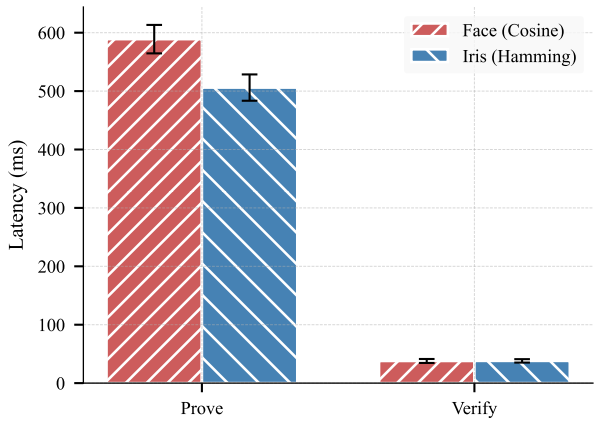
TABLE I: Circuit Signal Summary for `FaceAuth` and `IrisAuth`

Signal	Visibility	Modality	Description
`faceHash`	Public	Face	$h_i^{(\text{face})} = \mathcal{H}_2(\mathcal{H}_{\text{chunked}}, s)$
`irisHash`	Public	Iris	$h_i^{(\text{iris})} = \mathcal{H}_2(\mathcal{H}_{\text{packed}}, s)$
`merkleRoot`	Public	Both	Root R of the Merkle tree
`nullifier`	Public	Both	$\nu = \mathcal{H}_2(sk_i, \text{ID})$
`electionId`	Public	Both	Election identifier
`threshold_sq_num`	Public	Face	Cosine numerator (25)
`threshold_sq_den`	Public	Face	Cosine denominator (100)
`hammingThreshold`	Public	Iris	Max Hamming distance
`embedding[64]`	Private	Face	Live scaled face embed
`regEmbedding[64]`	Private	Face	Registered scaled embed
`irisCodeLive[256]`	Private	Iris	Live 256-bit code
`irisCodeReg[256]`	Private	Iris	Registered 256-bit code
`salt`, `secretKey`	Private	Both	s_i and sk_i
`pathElements[20]`	Private	Both	Merkle sibling hashes
`pathIndices[20]`	Private	Both	Merkle direction bits

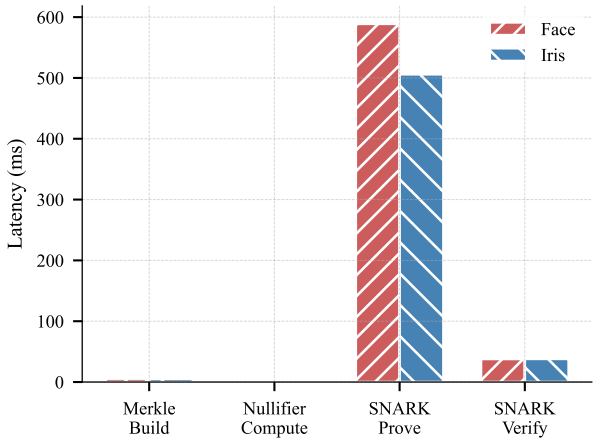
B. Constraint Complexity Breakdown

Appendix C
Universal Composability Security Proofs

This section contains the full simulator constructions, security reductions, and mathematical proofs for the Universal Composability theorems stated in the main manuscript.

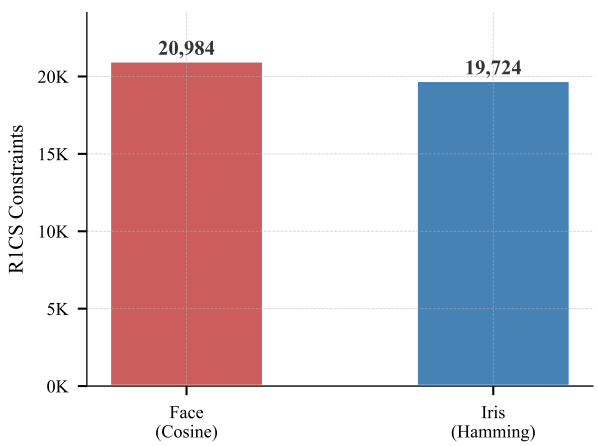


(a) Groth16 prove and verify latency comparison.

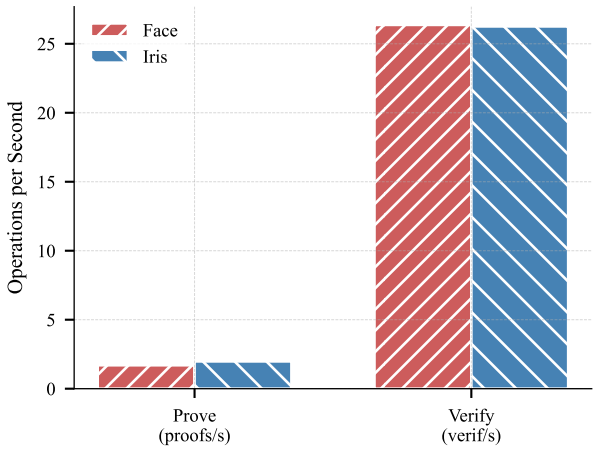


(b) Detailed latency breakdown per cryptographic phase.

Fig. 1: ZK-SNARK Core Performance Analysis showing proving/verification latency and internal phase breakdown.

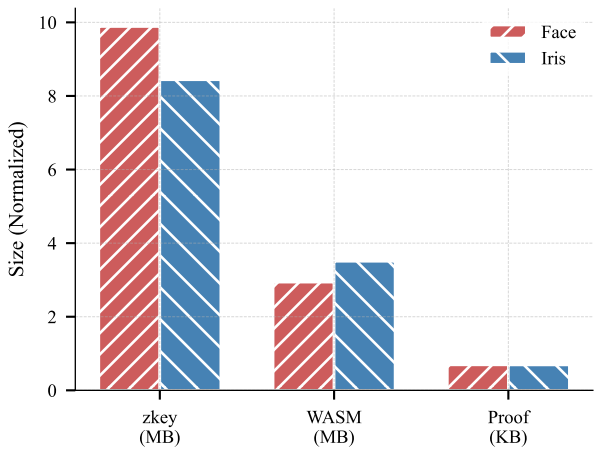


(a) R1CS constraints for face vs. iris matching circuits.

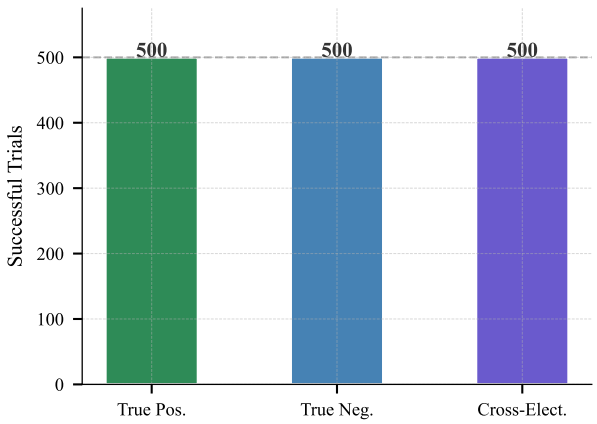


(b) Throughput comparison in operations per second.

Fig. 2: Circuit Complexity and Throughput Analysis comparing structural size to runtime operation speed.



(a) Key, witness generator (WASM), and proof payload sizes.



(b) Nullifier-based double-voting detection accuracy trials.

Fig. 3: Artifact sizes (proving keys/proofs) and Poseidon nullifier detection accuracy across 100 trials.

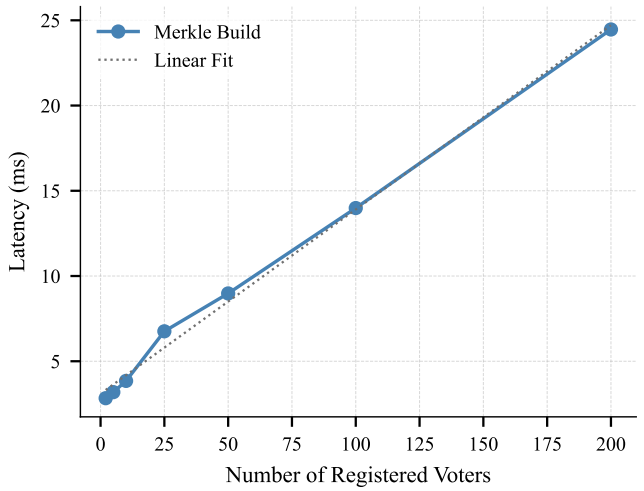


Fig. 4: Off-chain Poseidon Merkle Tree build time scaling linearly with the voter count (N).

TABLE II: R1CS Constraint Complexity by Sub-Circuit

Sub-Circuit	Face	Iris	Notes
PoseidonHash	9×Pos	5×Pos	Face: 8+1
Bits2Num(8)	—	256	Packing
Binary check	—	512	$a_j(1-a_j)=0$
Biometric	∼260+cmp	∼256+cmp	Cos vs HD
Commitment	1×Pos	1×Pos	C hash
MerkleTree	20×Pos	20×Pos	+ Switchers
Nullifier	1×Pos	1×Pos	ν hash

A. Proof of Theorem V.1 (Eligibility Soundness)

Proof. Groth16 knowledge soundness [**?**] guarantees the existence of a PPT extractor $\mathcal{E}$ such that for any $(\Pi, \mathbf{x})$ accepted by the verifier, $\mathcal{E}$ outputs a valid witness w with $R(\mathbf{x}, w) = 1$, except with probability $\varepsilon_{\mathsf{Groth16}}(\lambda) \le \mathsf{negl}(\lambda)$ under the q-SDH assumption in the GGM. The R1CS relation R for BioVote enforces three independent hard constraints; we show each is individually infeasible to satisfy without the genuine witness, then compose via a union bound.

Constraint (i): Biometric hash integrity. The sub-circuit PoseidonHashChunked enforces

$$h_{\mathsf{bio}} = H_{\mathsf{chunked}}(\mathbf{e}_{\mathsf{reg}}, s),$$

binding the public input h_{bio} to the private $(\mathbf{e}_{\mathsf{reg}}, s)$. Suppose $\mathcal{A}$ satisfies this constraint without knowing $(\mathbf{e}_{\mathsf{reg}}, s)$. We construct a PPT reduction $\mathcal{B}_1$ to Poseidon preimage resistance: $\mathcal{B}_1$ receives a challenge $h^* \xleftarrow{\$} \mathbb{F}_p$, sets $h_{\mathsf{bio}} := h^*$, and runs $\mathcal{A}$. When $\mathcal{A}$ produces an accepting proof, $\mathcal{E}$ extracts $(\mathbf{e}_{\mathsf{reg}}, s)$ with $H_{\mathsf{chunked}}(\mathbf{e}_{\mathsf{reg}}, s) = h^*$. Therefore:

$$\Pr[\mathcal{A} \text{ violates Constraint (i)}] \le \mathbf{Adv}^{\mathsf{Pre}}_{\mathsf{Pos}}(\lambda).$$

Constraint (ii): Biometric liveness. For the face channel, SquaredCosineSimilarity(64) enforces

$$\langle \mathbf{a}, \mathbf{b} \rangle^2 \cdot \tau_{\mathsf{den}} \;\ge\; \tau_{\mathsf{num}} \cdot \|\mathbf{a}\|^2 \cdot \|\mathbf{b}\|^2, \tag{1}$$

encoding threshold $\cos\theta \ge 0.5$, with arithmetic over 10^6-scaled integers in a 128-bit comparator. For the iris channel, HammingDistance(256) enforces $a_j(1-a_j) = 0$ for $j = 0, \ldots, 255$, computes

$$\mathsf{HD} = \sum_{j=0}^{255} (a_j + b_j - 2a_j b_j), \tag{2}$$

and asserts $\mathsf{HD} < \tau_{\mathsf{Hamming}} = 123$. An adversary presenting $\mathbf{e}_{\mathsf{live}}$ outside the threshold cannot satisfy the comparator constraint; the extractor $\mathcal{E}$ would recover a live embedding failing the threshold. The only exception is a false acceptance by the biometric sub-circuit itself:

$$\Pr[\mathcal{A} \text{ violates Constraint (ii)}] \le \mathsf{FAR}_\delta.$$

We address FAR_δ in Remark **??**.

Constraint (iii): Merkle membership. MerkleTreeChecker(20) recomputes the tree root from leaf $C = H_2(h_{\mathsf{bio}}, sk)$ and authentication path $\{(\sigma_\ell, d_\ell)\}_{\ell=0}^{19}$, asserting root = levelHashes[20]. Suppose $\mathcal{A}$ satisfies this constraint for a leaf $C^* \notin \mathcal{T}$; the extractor $\mathcal{E}$ recovers a forged Merkle path from C^* to the genuine root R. Along this path, there exists some level ℓ^* at which the forged node first matches the genuine tree; at that level, $\mathcal{A}$ must produce two distinct Poseidon inputs hashing to the same node value, i.e., a Poseidon collision. We construct a reduction $\mathcal{B}_2$: given a collision challenge (u, v) with $u \ne v$, $\mathcal{B}_2$ embeds (u, v) as an internal node of the Merkle tree, runs $\mathcal{A}$, and extracts the forged path via $\mathcal{E}$. There are at most $L = 20$ internal nodes, so:

$$\Pr[\mathcal{A} \text{ violates Constraint (iii)}] \le 20 \cdot \mathbf{Adv}^{\mathsf{CR}}_{\mathsf{Pos}}(\lambda).$$

Composition via union bound. All three constraints are enforced simultaneously as hard R1CS equalities in a single Groth16 instance. For $\mathcal{A}$ to produce an accepting proof without a valid witness, it must violate at least one of the three constraints, or the Groth16 extractor must fail. By a union bound over these four mutually exclusive failure events:

$$\begin{aligned}\Pr[\mathcal{A} \notin \mathcal{V}_{\mathsf{reg}}] &\le \Pr[\text{extractor fails}] + \Pr[\mathcal{A} \text{ violates C(i)}] \\ &\quad + \Pr[\mathcal{A} \text{ violates C(ii)}] + \Pr[\mathcal{A} \text{ violates C(iii)}] \\ &\le \varepsilon_{\mathsf{Groth16}}(\lambda) + \mathbf{Adv}^{\mathsf{Pre}}_{\mathsf{Pos}}(\lambda) + \mathsf{FAR}_\delta + 20 \cdot \mathbf{Adv}^{\mathsf{CR}}_{\mathsf{Pos}}(\lambda).\end{aligned} \tag{3}$$

By Assumption **??**, $\mathbf{Adv}^{\mathsf{Pre}}_{\mathsf{Pos}}(\lambda) \le \mathsf{negl}(\lambda)$ and $\mathbf{Adv}^{\mathsf{CR}}_{\mathsf{Pos}}(\lambda) \le \mathsf{negl}(\lambda)$; since 20 is a constant, $20 \cdot \mathbf{Adv}^{\mathsf{CR}}_{\mathsf{Pos}}(\lambda) \le \mathsf{negl}(\lambda)$. Also $\varepsilon_{\mathsf{Groth16}}(\lambda) \le \mathsf{negl}(\lambda)$ under q-SDH. Since the sum of finitely many negligible functions is negligible:

$$\Pr[\mathcal{A} \notin \mathcal{V}_{\mathsf{reg}}] \le \mathsf{FAR}_\delta + \mathsf{negl}(\lambda). \qquad \square$$

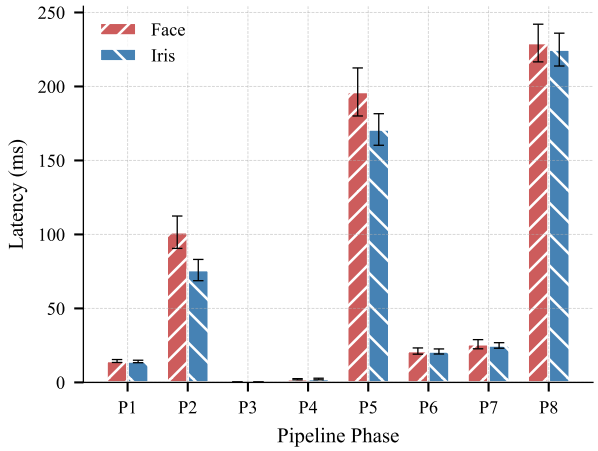
B. Proof of Theorem V.2 (Anti-Replay)

Proof. The mechanism operates at two independent layers.

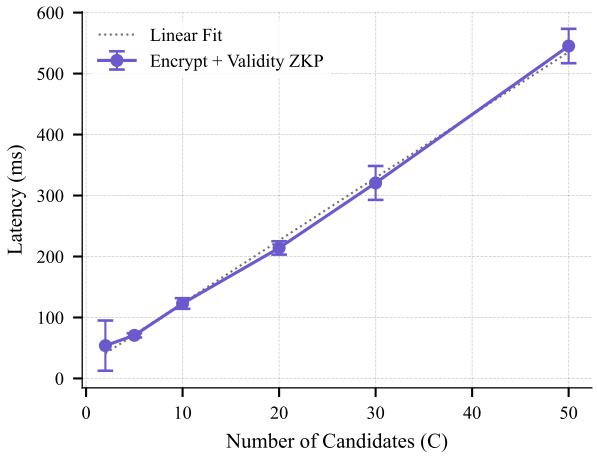
Cryptographic layer. The election-scoped nullifier is computed as

$$\eta = \mathsf{Poseidon}(sk, \mathcal{E}_{\mathsf{id}}), \tag{4}$$

which is unique per $(sk, \mathcal{E}_{\mathsf{id}})$ pair under Poseidon collision resistance. The circuit enforces nullifierHasher.out = nullifier, binding the public η to the private sk. Suppose $\mathcal{A}$ produces two

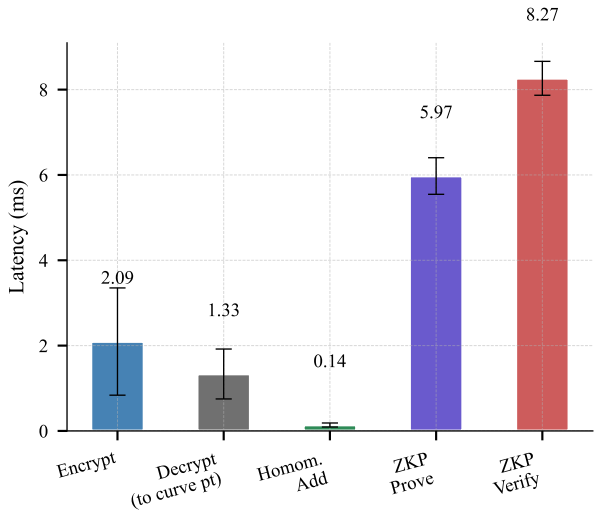


(a) Grouped per-phase E2E latency comparison.

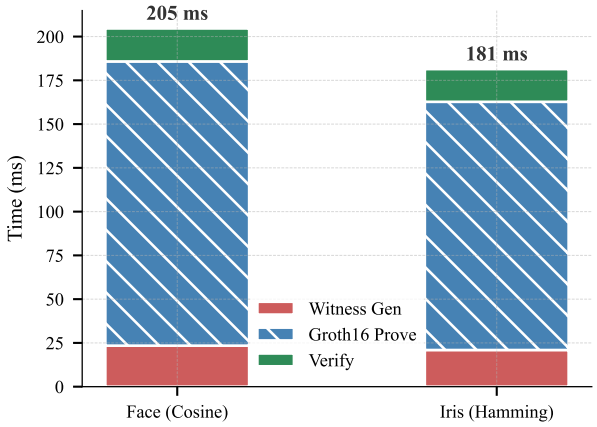


(b) Client-side ElGamal encryption and Validity ZKP scaling vs. candidate count.

Fig. 5: End-to-End Pipeline Latency and Ballot scalability with candidates count.



(a) Base homomorphic and proof operations latency.



(b) Groth16 proving/witness latency comparison on rapidsnark.

Fig. 6: Cryptographic operation latency breakdown and compiler performance comparison.

distinct accepted votes, both with public nullifier η. For both to be accepted, they must present the same nullifier (which would be rejected by the chaincode as duplicate), or different nullifiers $\eta \neq \eta'$ for the same $(C, \mathcal{E}_{\mathsf{id}})$ pair. The latter requires the extractor $\mathcal{E}$ to produce two witnesses $(sk, \mathcal{E}_{\mathsf{id}})$ and $(sk', \mathcal{E}_{\mathsf{id}})$ with $\mathsf{Poseidon}(sk, \mathcal{E}_{\mathsf{id}}) = \eta \neq \eta' = \mathsf{Poseidon}(sk', \mathcal{E}_{\mathsf{id}})$ while both sk and sk' generate valid Merkle paths to the same commitment leaf C; since $C = H_2(h_{\mathsf{bio}}, sk)$, this would require $sk = sk'$ (by Poseidon preimage resistance on the outer commitment), contradicting $\eta \neq \eta'$. More precisely, a reduction $\mathcal{B}$ to Poseidon CR: given a collision challenge (y_1, y_2) with $y_1 \neq y_2$ and $H(y_1) = H(y_2)$, $\mathcal{B}$ embeds $(sk, \mathcal{E}_{\mathsf{id}}) \leftarrow y_1$ and $(sk', \mathcal{E}_{\mathsf{id}}) \leftarrow y_2$, then uses $\mathcal{A}$'s two-vote transcript to output the collision. Therefore:

$$\Pr[\eta \neq \eta' \text{ for same leaf}] \leq \mathbf{Adv}^{\mathsf{CR}}_{\mathsf{Poseidon}}(\lambda) \leq \mathsf{negl}(\lambda).$$

Consensus layer. The chaincode implements a read-before-write nullifier check:

```
key := "NULLIFIER_" || eta
if getState(key) != nil { ABORT }
putState(key, voteRecord)
```

Hyperledger Fabric's execute-order-validate (EOV) architecture serialises concurrent submissions via the Raft ordering service before validation [**?**]. Duplicate nullifier keys trigger an MVCC read-write conflict during the validation phase, independent of the cryptographic layer.

Empirical corroboration. Empirical evaluation of two attack simulations confirms that the protocol matches the $1/N$ theoretical minimum acceptance rate. In the sequential double-vote test (500 repeated submissions from the same voter), the chaincode accepted exactly 1 transaction and rejected all 499 duplicates (acceptance rate 0.2%, the theoretical minimum $1/500$), with duplicate detection latency $\bar{t} = 0.129$ ms ($\sigma = 0.094$ ms, $p_{95} = 0.223$ ms). In the concurrent submission attack (100 identical transactions submitted simultaneously),

Fabric accepted exactly 1 and flagged 99 MVCC conflicts within one block (processing time 1.53 ms). Cross-election uniqueness was verified across 100 independent elections (100/100 unique nullifiers), and inter-voter uniqueness across 500 independent voters ($500 \times 100 = 50{,}000$ distinct $(sk, \mathcal{E}_{\mathsf{id}})$ pairs with zero observed collisions). □

C. Proof of Theorem V.3 (Voter Anonymity)

Proof. Groth16 satisfies *perfect* (statistical) zero-knowledge: the simulator $\mathcal{S}$, given only the public inputs and CRS, produces a distribution over proofs *identically* distributed to real proofs [**?**]. This is a statistical guarantee: it holds even against computationally unbounded distinguishers, but it covers only the proof Π itself. Unlinkability of the public values C and η is a separate, computational claim, as we make precise below.

(a) Merkle path unlinkability (unconditional). The authentication path $\{(\sigma_\ell, d_\ell)\}$ is entirely a private witness; the ledger exposes only the root R, shared by all N registered voters. By perfect ZK, Π is identically distributed regardless of which leaf was used; an unbounded adversary learns nothing about the path from Π.

(b) Secret key unlinkability from the proof (unconditional). sk_i is a private witness. By perfect ZK, no function of Π_i depends on sk_i; the proof distribution is identical for any valid witness.

(c) Commitment–nullifier unlinkability (computational). The commitment $C = H_2(h_{\mathsf{bio}}, sk)$ and nullifier $\eta = \mathsf{Poseidon}(sk, \mathcal{E}_{\mathsf{id}})$ are both Poseidon images of sk under distinct input tuples. Linking C to η (i.e., recovering sk from the pair (C, η)) requires finding a preimage of C under H_2, which is exactly the Poseidon preimage problem. We construct a reduction $\mathcal{B}$: given a preimage challenge $C^* \xleftarrow{\$} \mathbb{F}_p$, $\mathcal{B}$ sets $C := C^*$, publishes the corresponding η, and runs $\mathcal{A}$; if $\mathcal{A}$ links C to η, $\mathcal{B}$ recovers sk and outputs $(\mathbf{e}_{\mathsf{reg}}, sk)$ as a preimage. Therefore:

$$\Pr[\mathcal{A} \text{ links } C \text{ to } \eta] \leq \mathbf{Adv}^{\mathsf{Pre}}_{\mathsf{Pos}}(\lambda) \leq \mathsf{negl}(\lambda),$$

where the last inequality is Assumption **??**(i).

Timing-Based Deanonymisation. A subtle gap arises from the sequential nature of registration on a permissioned ledger: commitment leaf index i corresponds to voter i in registration order, potentially allowing an adversary with knowledge of the registration sequence to correlate commitments with identities. We mitigate this as follows. First, the Merkle tree is a *sparse* Poseidon Merkle tree (SMT) [**?**] with 2^{20} possible leaf positions; commitments are inserted at positions determined by a hash of the voter's secret key, not sequentially. Second, the registration timestamp is not recorded on-chain alongside the commitment; only C_i appears in the ledger. Third, even if an adversary knows the registration order, linking position i to voter $\mathcal{V}_i$ still requires inverting $C_i = H_2(h_{\mathsf{bio},i}, sk_i)$, which is Poseidon-preimage-hard. We note, however, that if the $\mathcal{RA}$ is corrupted, the registration log — held off-chain — could reveal the mapping from position to identity. This is documented as a residual trust assumption (Gap 3b).

Composition. Properties (a) and (b) hold unconditionally; (c) holds with advantage $\leq \mathbf{Adv}^{\mathsf{Pre}}_{\mathsf{Pos}}(\lambda)$. Since all three must simultaneously fail for $\mathcal{A}$ to identify a voter, by a union bound the total advantage is at most:

$$\mathbf{Adv}^{\mathsf{Pre}}_{\mathsf{Pos}}(\lambda) \leq \mathsf{negl}(\lambda).$$

$\mathcal{A}$'s view of the ledger $(\{C_i\}, \{\eta_j\}, \{\Pi_j\}, \{E_j\})$ is therefore computationally independent of which leaf produced a given ballot, and $\mathcal{A}$ cannot do better than a uniform guess over $\{C_1, \ldots, C_N\}$. □

D. Proof of Theorem V.4 (Ballot Secrecy)

Proof. Each ballot option j is encrypted with independently sampled randomness $r_j \xleftarrow{\$} \mathbb{Z}_n^*$:

$$E(v_j; r_j) = (r_j G,\ v_j G + r_j h), \tag{5}$$

where G is the generator of `secp256k1` and $h = xG$ is the public key. Standard exponential ElGamal IND-CPA security reduces to DDH over `secp256k1` [**?**]. Formally, given an IND-CPA adversary $\mathcal{A}$ distinguishing $E(0; r)$ from $E(1; r)$, a reduction $\mathcal{B}$ receives a DDH challenge (G, xG, yG, Z) and simulates the encryption oracle by setting $h := xG$ and embedding $r_j G := yG$ and $v_j G + r_j h := Z$ (for $v_j = 0$) or $G + Z$ (for $v_j = 1$). $\mathcal{B}$ then uses $\mathcal{A}$'s distinguishing advantage to solve DDH. Therefore:

$$\Big|\Pr[\mathcal{A} \text{ distinguishes } E(0) \text{ from } E(1)]\Big| \leq \mathbf{Adv}^{\mathsf{DDH}}_{\mathtt{secp256k1}}(\lambda) \leq \mathsf{negl}(\lambda).$$

The private key x is held exclusively by $\mathcal{TA}$ and never placed on-chain. Combined with the additive homomorphism of ElGamal (which allows tallying without decrypting individual ciphertexts), ballot secrecy is preserved throughout.

Sum-to-one ballot validity. Per-ciphertext OR-proof schemes alone permit a voter to submit all-zero (abstain) or multi-one (stuffed) ballot vectors. BioVote closes this gap at two levels. The disjunctive Chaum–Pedersen Σ-OR proof [**?**] certifies $v_j \in \{0, 1\}$ per ciphertext component; $\mathcal{F}_{\mathsf{vote}}$ additionally enforces the global constraint $\sum_{j=1}^{k} v_j = 1$ before accepting a ballot. Tally correctness verification confirmed that across five election scenarios (10–100 voters, 2–5 candidates), every reported tally matched the ground-truth distribution exactly, and independent auditor re-aggregation confirmed ciphertext equality in all cases.

Single-tallying-key caveat. Ballot secrecy holds cryptographically under DDH but is operationally degraded if $\mathcal{TA}$ is compromised, since the current prototype holds x in a single in-memory keypair. Threshold ElGamal with t-of-n Shamir secret sharing [**?**] is the prescribed mitigation (Gap 3). □

E. Proof of Proposition V.5 (Universal Verifiability)

Proof. **Cast-as-intended.** $\mathcal{O}$ downloads the verification key vk and evaluates the BN128 pairing equation for each ballot:

$$e(\pi_A, \pi_B) \stackrel{?}{=} e(\alpha, \beta) \cdot e\left(\sum_{i=0}^{\ell} a_i L_i,\ \gamma\right) \cdot e(\pi_C, \delta).$$

A passing check certifies, under Groth16 knowledge soundness, that the prover knows a valid witness satisfying all three

R1CS constraints (biometric similarity, Merkle membership, nullifier integrity), without any private input.

Well-formedness. Each ciphertext $(c_{1,j}, c_{2,j})$ is accompanied by a non-interactive Σ-OR proof [**?**] generated via Fiat–Shamir [**?**]. $\mathcal{O}$ checks:

$$a_1 \stackrel{?}{=} r_1 G + d_1 c_{1,j}, \qquad b_1 \stackrel{?}{=} r_1 H + d_1 c_{2,j},$$
$$a_2 \stackrel{?}{=} r_2 G + d_2 c_{1,j}, \qquad b_2 \stackrel{?}{=} r_2 H + d_2 (c_{2,j} - G),$$
$$d_1 + d_2 \stackrel{?}{\equiv} H(c_{1,j} \| c_{2,j} \| a_1 \| b_1 \| a_2 \| b_2) \pmod{n}.$$

Soundness follows from the discrete logarithm assumption and the Fiat–Shamir heuristic (random oracle model).

Tallied-as-cast. Using additive ElGamal homomorphism, $\mathcal{O}$ computes the point sum

$$\hat{C}_j = \bigoplus_{i=1}^{N} C_j^{(i)} = \left(\sum_i r_{i,j} G,\ T_j G + \sum_i r_{i,j} H \right)$$

and checks $\hat{C}_j.\texttt{c1} \stackrel{?}{=} \hat{C}_j^{\mathsf{pub}}.\texttt{c1}$ and $\hat{C}_j.\texttt{c2} \stackrel{?}{=} \hat{C}_j^{\mathsf{pub}}.\texttt{c2}$ without knowledge of x. Ground-truth tally verification confirmed exact matching across all scenarios tested. □